

ISO 31000 — Gestión del Riesgo

1. Introducción y contexto

ISO 31000 es la norma internacional que proporciona principios, un marco de referencia y un proceso genérico para gestionar el riesgo, aplicable a cualquier tipo de organización, sector o actividad. A diferencia de normas certificables como ISO 9001 o ISO/IEC 27001, ISO 31000 es una norma de directrices (guidance), no está diseñada para certificación, sino para ser adoptada como referencia conceptual y metodológica. Para un estudiante de Informática, esta norma resulta clave porque el "pensamiento basado en riesgos" que exigen normas como ISO 9001, ISO/IEC 27001 o ISO/IEC 20000 se apoya conceptualmente en los principios y el proceso definidos por ISO 31000.

2. Historia y evolución

- Publicada por primera vez en 2009, como resultado de un esfuerzo internacional por unificar los distintos estándares de gestión de riesgos existentes (como el estándar australiano/neozelandés AS/NZS 4360).
- Revisada en 2018, simplificando su estructura y reforzando el rol del liderazgo y la integración de la gestión de riesgos en todos los niveles de la organización, en lugar de tratarla como una actividad aislada.

3. Objetivo y alcance

El objetivo es ayudar a las organizaciones a aumentar la probabilidad de alcanzar sus objetivos, mejorar la identificación de oportunidades y amenazas, y asignar y utilizar eficazmente los recursos para el tratamiento del riesgo. Es aplicable a cualquier tipo de riesgo (financiero, operacional, tecnológico, de seguridad, de proyecto), en cualquier organización y en cualquier etapa de una actividad.

4. Organismo emisor

Desarrollada por el comité técnico ISO/TC 262 (Gestión del riesgo), formado por expertos internacionales de múltiples disciplinas.

5. Estructura general (versión 2018)

La norma se organiza en tres componentes principales:

1. Principios: fundamentos que explican por qué y cómo debe gestionarse el riesgo.
2. Marco de referencia (Framework): estructura organizacional que integra la gestión de riesgos en la gobernanza y en todas las actividades de la organización.
3. Proceso: pasos sistemáticos para gestionar el riesgo en la práctica.

6. Conceptos y terminología clave

- Riesgo: efecto de la incertidumbre sobre los objetivos; puede ser positivo (oportunidad) o negativo (amenaza).
- Probabilidad: posibilidad de que algo ocurra.
- Impacto (consecuencia): efecto de un evento sobre los objetivos.
- Apetito de riesgo: cantidad y tipo de riesgo que una organización está dispuesta a asumir para lograr sus objetivos.
- Tratamiento del riesgo: proceso para modificar el riesgo (evitar, mitigar, transferir, aceptar).
- Parte interesada (stakeholder): persona u organización que puede afectar, verse afectada

por, o percibirse a sí misma como afectada por una decisión o actividad relacionada con el riesgo.

7. Los ocho principios de la gestión del riesgo

- Integrada: la gestión de riesgos es parte de todas las actividades de la organización, no un proceso aislado.
- Estructurada y exhaustiva: contribuye a resultados consistentes y comparables.
- Adaptada (a medida): el marco y el proceso se ajustan al contexto externo e interno de la organización.
- Inclusiva: la participación adecuada y oportuna de las partes interesadas permite considerar su conocimiento y percepciones.
- Dinámica: los riesgos pueden surgir, cambiar o desaparecer conforme cambia el contexto de la organización.
- Mejor información disponible: las entradas se basan en información histórica, actual y en expectativas futuras.
- Factores humanos y culturales: el comportamiento humano y la cultura influyen significativamente en la gestión del riesgo.
- Mejora continua: la gestión del riesgo se perfecciona continuamente mediante el aprendizaje y la experiencia.

8. El proceso de gestión del riesgo explicado

Comunicación y consulta Actividades continuas realizadas con las partes interesadas para informar y recibir retroalimentación durante todo el proceso. Establecimiento del contexto (alcance, contexto y criterios) Define el alcance del proceso, y el contexto externo e interno relevante, así como los criterios de riesgo que se usarán para evaluar su importancia. Valoración del riesgo (Risk Assessment) Se compone de tres actividades:

- Identificación del riesgo: reconocer y describir los riesgos que podrían afectar los objetivos.
- Análisis del riesgo: comprender la naturaleza del riesgo y determinar su nivel, considerando probabilidad e impacto.
- Evaluación del riesgo: comparar los resultados del análisis con los criterios de riesgo establecidos, para decidir si el riesgo requiere tratamiento.

Tratamiento del riesgo Selección e implementación de una o varias opciones para modificar el riesgo: evitar el riesgo, aceptar o aumentar el riesgo para aprovechar una oportunidad, eliminar la fuente del riesgo, cambiar la probabilidad o las consecuencias, compartir el riesgo (por ejemplo mediante un seguro o un contrato), o retener el riesgo mediante una decisión informada. Seguimiento y revisión Verificación continua de la eficacia del proceso de gestión de riesgos y de los resultados obtenidos. Registro e informe Documentación del proceso y sus resultados para comunicación, rendición de cuentas y mejora continua.

9. Proceso de implementación del marco de referencia

4. Obtener liderazgo y compromiso de la alta dirección.
5. Diseñar el marco: comprender la organización y su contexto, articular el compromiso, asignar roles, autoridades y recursos.
6. Implementar el marco en los procesos de toma de decisiones de la organización.
7. Evaluar la eficacia del marco.
8. Mejorar el marco de forma continua, adaptándolo a cambios internos y externos.

10. Relación con otras normas

- ISO 9001 e ISO/IEC 27001: incorporan explícitamente el "pensamiento basado en riesgos" que se apoya en los conceptos de ISO 31000.
- ISO/IEC 27005: aplica los principios de ISO 31000 específicamente a la gestión de riesgos de seguridad de la información.
- ISO 22301:

gestión de continuidad de negocio, que utiliza la evaluación de riesgos como insumo para identificar amenazas a la continuidad operativa. • ISO 31010: norma técnica complementaria que detalla técnicas específicas de valoración de riesgos (matrices de riesgo, árboles de fallos, análisis FMEA, entre otras).

11. Aplicación práctica en informática

- Evaluación de riesgos en proyectos de software (retrasos, sobrecostos, cambios de alcance).
- Identificación de riesgos tecnológicos en la adopción de nuevas plataformas o migraciones a la nube.
- Base metodológica para la evaluación de riesgos de ciberseguridad exigida por ISO/IEC 27001.
- Apoyo en la toma de decisiones sobre arquitectura de sistemas críticos, considerando riesgos de disponibilidad y escalabilidad.

12. Caso de aplicación ilustrativo

El equipo de un proyecto de migración de infraestructura a la nube aplica el proceso de ISO 31000: identifica riesgos como pérdida de datos durante la migración, incompatibilidad de sistemas heredados y interrupción del servicio. Analiza la probabilidad e impacto de cada riesgo, decide tratar el riesgo de pérdida de datos mediante copias de seguridad redundantes (mitigación) y transferir el riesgo de interrupción del servicio contratando un proveedor con garantías contractuales de disponibilidad (compartir el riesgo).

13. Preguntas de repaso

- ¿Por qué ISO 31000 no es una norma certificable, a diferencia de ISO 9001 o ISO/IEC 27001?
- Explica la diferencia entre identificación, análisis y evaluación del riesgo dentro de la valoración del riesgo.
- Menciona las opciones de tratamiento del riesgo descritas por la norma.
- ¿Cómo se relaciona ISO 31000 con ISO/IEC 27005?
- Da un ejemplo de riesgo positivo (oportunidad) en un contexto de proyectos tecnológicos.

14. Glosario breve

- **Apetito de riesgo:** nivel de riesgo que una organización está dispuesta a aceptar.
- **Matriz de riesgo:** herramienta visual que combina probabilidad e impacto para priorizar riesgos.
- **Riesgo residual:** riesgo que permanece después de aplicar el tratamiento correspondiente.

15. Para profundizar

Se recomienda consultar el texto oficial de ISO 31000:2018 y la norma técnica complementaria ISO 31010 sobre técnicas de valoración de riesgos, disponibles a través de los canales autorizados de ISO.